Bosch Security Systems Firmware Attack Surface & Detection Brief

Bosch Security Systems Firmware Attack Surface & Detection Brief

Scope: CVE/public-advisory research, plus a real firmware acquisition and extraction attempt (update 2026-10-21). Two real firmware packages were pulled directly from Bosch's open download store (`downloadstore.boschsecurity.com/?type=FW`, no login required) — CPP7.3 v7.93.0024 (`CPP7.3_FW_7.93.0024.fw`, 95,217,328 bytes, SHA256 `66989c278dc7281a770e77a605ff988ef59ab3102e1e6d27c38e7ae11b46b9f9`) and CPP4 v7.10.0096 (`CPP4_H.264_7.10.0096.fw`, 53,108,976 bytes, SHA256 `e3932d56556b4e391d74ff62390e34e6a1f5aba4756e604a0ce361bcaa2261b6`) — the same CPP generation family this brief's CVE research already covers. CPP13/CPP14 current-generation firmware was found and confirmed downloadable too (`CPP13_FW_8.94.0041.fw`, `CPP14_FW_9.82.0022.fw`) but at 1.0-1.1 GB each was not pulled this pass. Both acquired files were run through this project's standard binwalk-based extraction pipeline (`Expand-EatonFirmware.ps1` + WSL/binwalk 3.1.0). **Result: zero binwalk signatures matched in either file**, and `strings` output on both is high-entropy, non-linguistic noise rather than readable embedded text — consistent with the whole firmware image being encrypted at rest, not merely signed. No rootfs, service list, or config file could be extracted from either file with this tooling. This is itself a real finding: Bosch's own CPP13 release-letter language about a "new signature [protecting] from non-released versions being installed" is consistent with what was observed, and the encryption (if that is what this is, rather than an unrecognized proprietary container) would be a stronger anti-tamper posture than some other vendors already covered in this project (e.g. the Eaton brief's Group B finding that ESP32 NMC firmware flashes with no signature verification at all). Treat every CVE finding below as research-anchored, not firmware-content-verified — that part of the brief is unchanged by this extraction attempt. There are no carved files or service-enumeration output to present, by finding, not by omission.

Purdue layer mapping: Bosch IP cameras and intrusion/control panels are **Purdue L1 field devices** in the physical-security domain — the direct sensing/actuation layer (camera sensor + encoder, door/motion-contact sensing + siren/relay output), analogous in role to the chassis/compact PLCs and RTUs documented in purdue-l1-basic-controllers-brief.md. That document's current scope and architecture-grouping table cover only industrial-process-control roles (chassis PLC, compact PLC, DCS controller, RTU, protective relay, VFD) — it does **not** yet include a physical-security/building-automation field-device class, confirmed by reading it directly rather than assumed. This brief is, as far as the existing docs show, the first in this project to map a physical-security field device into the L1 role, and the L1 brief should gain a "Physical Security Field Device" group (cameras, intrusion panels, door controllers, intercoms) once this vendor and its four parallel siblings in this batch — Tridium, Johnson Controls, Mercury Security, Axis Communications, Aiphone — are all written. The upstream management plane (BVMS / DIVAR IP video management appliances) sits at **Purdue L3.5 (IT/OT Boundary)**, the same role Eaton's NMCs and PDU G3 occupy for power infrastructure — it is the IP-

network bridge between the L1 camera/panel fleet and corporate IT, and it is where several of the highest-severity CVEs below land.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	CVE pattern
A. IP Camera (CPP platform)	L1 (physical security field device)	CPP4 / CPP6 / CPP7 / CPP7.3 / CPP13 / CPP14 "Common Product Platform" camera and encoder lines (Autodome, Dinion, Flexidome, AVIOTEC)	Embedded Linux, Bosch proprietary **RCP+** management protocol (TCP/1756, UDP/1800 discovery), ONVIF (TCP/3702 discovery), RTSP (TCP/554) streaming, embedded web UI	Missing/weak authentication on the RCP+ and web management plane, a web-server buffer overflow, CSRF, and a hardware side-channel key-extraction finding
B. Intrusion panel — legacy Conettix comms module	L1	B420, B426, B426-CN/B429-CN, B426-M	Bare-metal/legacy communication module; B420 already end-of-life since 2013	**IP-address-based** rather than credential-based authorization (B420), session hijacking in the web config interface (B426 family)
C. Intrusion panel — MAP 5000 (current)	L1	MAP 5000 family	Embedded Linux, TLS and SSH management interfaces, bundled OpenSSL/OpenSSH	Not Bosch-original logic bugs — every 2025 MAP 5000 advisory is an **inherited third-party crypto-library weakness** (weak Diffie-Hellman, SSH Terrapin prefix truncation, an 18-year-old OpenSSH signal-handler DoS, deprecated SSH ciphers)
D. Video management / recording appliances	L3.5 (IT/OT boundary — management plane over the L1 camera fleet)	BVMS (Bosch Video Management System), DIVAR IP 2000/3000/4000/5000/6000/7000 all-in-one recorders, Video Recording Manager, Configuration Manager	Windows/Linux appliance running RCP+, SSH, .NET services, OpenSSL	Unauthenticated RCP+ port, deserialization RCE, path traversal (authenticated and unauthenticated), XXE, SSH port-forwarding abuse, OpenSSL/OpenSSH bundled-CVE exposure

---

Group A — IP Camera (CPP platform) — Purdue L1

Confirmed CVEs (all verified directly against the Bosch PSIRT advisory index, `psirt.bosch.com/security-advisories/`):

CVE	Advisory	CVSS	Product	Vector
CVE-2018-19036	BOSCH-2018-1202-BT	9.4 (Bosch) / 9.8 (NVD)	CPP4/CPP6/CPP7 firmware ≥6.32 (e.g. AUTODOME IP 5000 HD, DINION HD 1080p)	Buffer overflow in the embedded web server → unauthenticated remote code execution
CVE-2021-23847	BOSCH-SA-478243-BT	9.8	CPP6/CPP7/CPP7.3, firmware 7.70/7.72, and <7.80 B128	Missing authentication in a critical function → unauthenticated extraction of sensitive data and settings change
CVE-2021-23848, -23852, -23853	BOSCH-SA-478243-BT (same advisory)	8.3 / 4.9 / 8.3	CPP4/CPP6/CPP7/CPP7.3/CPP13 (all listed firmware)	Companion bugs bundled in the same multi-CVE advisory; fixed in CPP4 7.10.0095, CPP6/7/7.3 7.62.0005 or 7.80.0129, AVIOTEC 7.72.0013, CPP13 7.75.0008
CVE-2021-23854	BOSCH-SA-478243-BT	n/r	CPP6/7/7.3 (7.70, 7.72), CPP13 (7.75, 7.76)	Same advisory family
CVE-2021-23849	BOSCH-SA-033305-BT	7.5	Bosch IP cameras	CSRF
CVE-2021-3011	BOSCH-SA-762869-BT	4.2	Bosch IP cameras and encoders	Side-channel key extraction
CVE-2023-39509	BOSCH-SA-638184-BT	7.2	Bosch IP cameras	Command injection
CVE-2022-41677	BOSCH-SA-839739-BT	5.3	Bosch IP cameras	Information disclosure
CVE-2023-32229	BOSCH-SA-435698-BT	4.9	Bosch IP cameras	Possible damage of secure element
CVE-2024-58330	BOSCH-SA-659648-BT	7.5	CPP13/CPP14	Missing authentication → unauthenticated retrieval of video-analytics event data (motion/object detection)

No public CVE was found specifically naming the CPP14 platform in isolation outside CVE-2024-58330 — treat any other CPP14-specific claim as unresearched for this brief.

Top attack vector (MITRE ATT&CK ICS): T0888 Remote System Information Discovery via the unauthenticated RCP+/video-analytics channel (CVE-2024-58330, CVE-2021-23847) to fingerprint camera make/model/firmware and pull analytics metadata, followed by T0859 Valid Accounts or direct exploitation to reach the settings-change path these same bugs expose.

Group B — Intrusion panel, legacy Conettix (B420 / B426 family) — Purdue L1

CVE	Advisory	CVSS	Product	Vector
CVE-2022-	BOSCH-SA-341298-BT	7.6 (Bosch CNA) / 8.8	B420 legacy communication module,	Improper access control — authorization is **IP-address-based, not credential-based**; any host

CVE	Advisory	CVSS	Product	Vector
47648		(NVD)	all firmware versions	reachable on the panel's network segment reaches the control panel without authentication. Module was already EOL since 2013.
CVE-2021-23845	BOSCH-SA-196933-BT	8.8	B426, B426-CN/B429-CN, B426-M, firmware < 03.08 (< 03.10 for -M)	Session hijacking in the web configuration interface → remote authentication bypass. Credited to Chizuru Toyama / TXOne; fixed from firmware 3.08 (June 2019).
CVE-2021-23846	BOSCH-SA-196933-BT (same advisory)	n/r	Same B426 family	Companion finding in the same multi-CVE advisory

Top attack vector: T0859 Valid Accounts is the wrong model here — both B420 and B426 bugs are **authentication-bypass-without-credentials**, i.e. T0831 Manipulation of Control reached directly by network position rather than by stolen creds. Any host that can route to the panel's management segment is, functionally, an authorized operator.

Group C — Intrusion panel, MAP 5000 (current generation) — Purdue L1

All five MAP 5000 advisories published 2025-11-19 are **inherited third-party library weaknesses**, not Bosch application-logic bugs — worth calling out because it changes the remediation story (firmware/bundle update pulls in a patched OpenSSL/OpenSSH, not a Bosch code fix):

CVE	Advisory	CVSS	Vector	Fix
CVE-2025-4995	BOSCH-SA-873110-BT	7.4	Weak Diffie-Hellman key exchange in the TLS server → passive decryption or MITM of secured management traffic	Bundle ≥1.48.0, firmware 1.4.0288
CVE-2006-5051	BOSCH-SA-085467-BT	8.1	OpenSSH signal-handler race condition → DoS (an 18-year-old upstream OpenSSH bug still present in the MAP 5000's bundled SSH stack as of the 2025 advisory)	Bundle ≥1.48.0, firmware 1.4.0288
CVE-2025-60034	BOSCH-SA-359440-BT	7.4	Deprecated SSH cryptographic settings	Bundle ≥1.48.1
CVE-2021-3449	BOSCH-SA-688644-BT	5.9	OpenSSL TLS renegotiation NULL-pointer DoS	Per advisory
CVE-2023-48795	BOSCH-SA-688644-BT (same)	5.9	SSH "Terrapin" prefix-truncation attack on the transport integrity	Per advisory

Top attack vector: T0814 Denial of Service via the OpenSSH/OpenSSL bundled bugs, with the weak-DH finding (CVE-2025-4995) as the more interesting passive-collection vector against the panel's engineering/management channel — T0859 Valid Accounts becomes reachable if session material is recovered from a broken-DH handshake.

Group D — Video management / recording appliances (BVMS, DIVAR IP) — Purdue L3.5

This is the Eaton-Group-F analog for this vendor: the highest-CVSS, most-exploitable findings sit on the Windows/Linux management appliance that supervises the camera fleet, not on the cameras themselves.

CVE	Advisory	CVSS	Product	Vector
CVE-2019-6958	BOSCH-2019-0404-BT	9.8	BVMS ≤9.0, DIVAR IP 2000/3000/5000/7000, Configuration Manager, BIS (Video Engine), APE, AEC, BVC, Video SDK	**RCP+ port reachable without authentication** — matches the same "no login required" posture that makes this vendor's own download store an outlier; here it's a bug class instead of a vendor convenience
CVE-2019-6957	BOSCH-2019-0403-BT	9.8	Same product family	Buffer overflow
CVE-2020-6770	BOSCH-SA-885551-BT	10.0	BVMS Mobile Video Service, ≤10.0.0.1225	Deserialization of untrusted data → unauthenticated remote code execution
CVE-2020-6768	BOSCH-SA-815013-BT	8.6	BVMS NoTouch deployment, ≤10.0.0.1225	Unauthenticated path traversal → arbitrary file read on the Central Server
CVE-2020-6767	BOSCH-SA-381489-BT	7.7	BVMS FileTransferService, ≤10.0.0.1225	Authenticated path traversal
CVE-2021-26701	BOSCH-SA-110112-BT	9.8	BVMS, BIS, AMS	.NET remote code execution
CVE-2018-1285	BOSCH-SA-506619-BT	9.8	BVMS	XXE
CVE-2023-28175	BOSCH-SA-025794-BT	7.1	BVMS 11.0 / 11.1.0 / 11.1.1	Improper authorization in the SSH server → authenticated remote user reaches the trusted internal network via port forwarding
CVE-2024-33618	BOSCH-SA-162032-BT	7.5	BVMS	Unrestricted resource consumption (DoS)

Top attack vector (MITRE ATT&CK ICS): T0843 Program Download-equivalent — the deserialization RCE (CVE-2020-6770) and unauthenticated RCP+ reachability (CVE-2019-6958) both land an attacker directly on the Central Server that holds every camera's credentials and video archive, making this the single highest-value pivot point against the entire fleet, consistent with the "compromise the management host" pattern documented for Eaton's Windows-side tooling.

Logging / detection matrix (ordered by detection value)

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	**Network IDS (Suricata/Zeek)**	RCP+ (TCP/1756) session establishment from a host with no prior auth handshake, or from outside the VMS/management VLAN	Unauthenticated RCP+ reachability (CVE-2019-6958, CVE-2021-23847-class bugs)	T0888 Remote System Information Discovery
2	Network IDS	RTSP (TCP/554) SETUP/PLAY requests from client IPs outside the known VMS/recorder set	Unauthorized stream pull / camera-feed exfiltration	T0888
3	Network IDS	ONVIF (TCP/3702, SOAP over HTTP) `GetDeviceInformation` / `GetSystemLog` bursts across many camera IPs in a short window	Fleet-wide reconnaissance sweep (252-device fleet makes this a realistic volumetric signal)	T0846 Remote System Discovery
4	**Camera/panel firmware-update log** (where exposed via BVMS/Configuration Manager audit)	Firmware push outside a scheduled maintenance window, or push not originating from the admin's known Configuration Manager host	Unsigned/unexpected firmware tamper	T0857 System Firmware
5	**Intrusion panel event log**	Arm/disarm event with no matching badge-swipe or keypad-PIN entry in the access-control log, or a disarm immediately followed by a door/motion event outside schedule	Direct manipulation of the physical-security control function via the B420/B426 auth-bypass or MAP 5000 session compromise	T0831 Manipulation of Control
6	Network IDS	TLS ClientHello/ServerHello on the MAP 5000 management port offering/accepting DHE with a non-standard (weak) group, or SSH KEXINIT negotiating a deprecated cipher	Passive exploitation attempt of CVE-2025-4995 / CVE-2025-60034	T0859 Valid Accounts (credential/session recovery precursor)
7	**BVMS / Central Server auth log**	`login.failure` bursts followed by `login.success`, or any login from a service account outside its normal source host	Brute force or credential-stuffing success against the management plane	T0812 Default Credentials / T0859 Valid Accounts
8	Network IDS	SSH session on the BVMS SSH server with port-forward (`-L` / `-R`) requests to internal, non-video-segment destinations	CVE-2023-28175 port-forwarding abuse into the trusted internal network	T0855 Unauthorized Command Message

Secondary:

- Firewall: no camera or intrusion panel should ever originate outbound traffic to a non-RFC1918 destination — these are L1 field devices with no legitimate reason to reach the internet directly.

- BVMS/Configuration Manager audit categories: enable "device access," "configuration change," and "firmware update" logging and forward to the SIEM via syslog or the Windows Event log forwarder, the same way Eaton's NMC audit categories are handled.
- Physical/cyber correlation: an alarm panel disarm event with no corresponding video-recording gap, or a video-recording gap with no corresponding maintenance ticket, is the OT-native anomaly signal for this device class — it is the physical-security equivalent of the UPS battery-test/load-drop signals used for power infrastructure.

Specific concerns for this dataset

1. **252 devices makes Bosch Security a top-tier OT vendor in this census by device count** — ahead of the industrial-process-control vendors (Rockwell, SEL, Siemens PLCs) that the existing 14 firmware briefs are weighted toward. The ARNG's actual OT population in this inventory is dominated by building-automation/physical-security vendors, and this brief (plus its five parallel siblings — Tridium, Johnson Controls, Mercury Security, Axis Communications, Aiphone) is the first attempt to close that documentation gap. Any detection or patching program built only from the original 14 briefs would have no coverage for the single largest OT vendor segment in the real inventory.

2. **No firmware has been pulled yet, despite the easiest access path of any vendor in this batch.** `downloadstore.boschsecurity.com` requires no login — unlike most of the other five vendors being researched in parallel, where acquisition is gated or requires a dealer/partner account. Pulling CPP6/CPP7/CPP13/CPP14 camera firmware and MAP 5000 bundle images should be the immediate fast-follow: it would let this project confirm (a) which of the 252 devices are actually running the vulnerable CPP firmware ranges identified above (7.70/7.72/<7.80 B128 for CVE-2021-23847; <6.32-patched for CVE-2018-19036), and (b) whether the MAP 5000 bundle version in the field has the 2025-11-19 crypto fixes.

3. **The intrusion-panel findings split cleanly into two very different risk profiles.** The legacy Conettix B420/B426 family (EOL since 2013) has **no credential model at all** in its vulnerable state — authorization is IP-address-based — so network segmentation is the only real control, not patching (B420 has no fix path; B426 fixed in 2019 firmware if any are still running pre-3.08/3.10). The current MAP 5000 line, by contrast, has a real patch path, but every 2025 CVE against it is an **inherited OpenSSL/OpenSSH library weakness**, meaning the panel's own application logic has had no new public CVE since the B420/B426 disclosures — treat that as "not yet scrutinized," not "secure," per the same EOL-device caution the Eaton brief applies to the NmcKA family.

4. **The BVMS/DIVAR IP management plane is the actual high-value target, not the cameras.** CVE-2020-6770 (CVSS 10.0, unauthenticated deserialization RCE) and CVE-2019-6958 (CVSS 9.8, unauthenticated RCP+ reachability) both land on the Central Server that holds credentials and recordings for the entire managed camera fleet. If any DIVAR IP appliance in this inventory is pre-10.0.0.1225 BVMS or pre-9.0 on the RCP+ bug, it is a single point of compromise for all cameras it manages — the same pattern as Eaton's "compromise the admin host" finding for UPS Companion/IPM, just on the physical-security side of the house.

Sources

- Bosch PSIRT — Security Advisories index
- Bosch Security Systems (US) — Security Advisories (redirects to keenfinity-group.com)
- BOSCH-SA-478243-BT — Multiple vulnerabilities in Bosch IP cameras (CVE-2021-23847 et al.)
- BOSCH-SA-341298-BT — Insecure authentication in B420 legacy communication module (CVE-2022-47648)
- CVE-2021-23847 — GCVE record
- CVE-2022-47648 — GCVE record
- CVE-2018-19036 — Tenable OT plugin / CVE record
- CVE-2021-23845 — Tenable OT plugin (B426 Conettix)
- CVE-2021-23845 — ZDI-21-644 advisory
- TXOne Networks — Researcher discovers vulnerabilities in Bosch Ethernet modules (CVE-2021-23845 credit)
- CVE-2024-58330 — SentinelOne vulnerability database (CPP13/CPP14)
- CVE-2019-6958 — NVD
- INCIBE-CERT — CVE-2019-6958 record
- INCIBE-CERT — Multiple vulnerabilities in MAP 5000 family (CVE-2025-4995, CVE-2006-5051, CVE-2025-60034)
- Bosch download store (open, no login)
- Keenfinity knowledge base — Bosch IP video device ports (RCP+ 1756/1757/1758, RTSP 554, ONVIF 3702)
- MITRE ATT&CK for ICS — T0888 Remote System Information Discovery
- MITRE ATT&CK for ICS — T0846 Remote System Discovery
- MITRE ATT&CK for ICS — T0859 Valid Accounts
- MITRE ATT&CK for ICS — T0814 Denial of Service
- MITRE ATT&CK for ICS — T0831 Manipulation of Control
- MITRE ATT&CK for ICS — T0857 System Firmware
- MITRE ATT&CK for ICS — T0855 Unauthorized Command Message
- eaton-firmware-threat-brief.md — structural/format template for this brief
- purdue-l1-basic-controllers-brief.md — read directly to confirm current scope does not yet include physical-security field devices